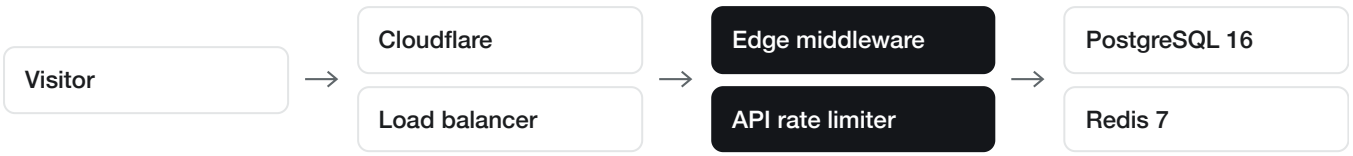
example.com security overview

Request flow



Stack

Hosting	**AWS, eu-west-1**	Node.js	**22.11**
Next.js	**15.3.2**	React	**19.1.0**
Auth.js	**5.0.0**	Prisma	**6.8.2**
PostgreSQL	**16, TLS**	Redis	**7.2**
pnpm	**9.15.0**	TypeScript	**5.8.3**

Firewall rules

Rule	Catches
SQL injection	Union selects, always-true conditions, time delays, stacked statements
Cross-site scripting	Script tags, script links, inline event handlers, embedded frames
Path traversal	Parent directory walks, system file reads
Command injection	Chained shell commands, Log4Shell lookups, template injection
Request forgery (SSRF)	Cloud metadata address, local file links

Rate limits

Traffic	Limit	Over limit
Pages	1,200 / min	429
API	300 / min	429
Sign-in	10 / 15 min	**Blocked**
Password reset	3 / hour	429
Contact form	5 / 10 min	Rejected

Automatic IP blocks

Trigger	Threshold	Window
Failed sign-ins	10	15 min
Password spraying	5 accounts	15 min
Attack payloads	3	1 hour
Probing unknown paths	50	5 min

Block length

15 min → 1 h → 4 h → 24 h → 7 d

API limits

Request body	**1 MB**	File upload	**20 MB, signed in**
GraphQL depth	**6**	Introspection	**Off in production**
CORS	**Own origin**	CSRF	**Double-submit token**

Sign-in and admin access

Two-factor	**Required for admins**	Passkeys	**Supported**
Session	**12 hours**	Cookies	**HttpOnly, Secure, Lax**
Account lock	**10 failures, 30 min**	Admin panel	**Office IPs only**

Security headers

Header	Value
Strict-Transport-Security	2 years, subdomains included, preload
Content-Security-Policy	Nonce per request, no plugins, same-origin framing
X-Content-Type-Options	`nosniff`
Referrer-Policy	Origin only on cross-site requests
Permissions-Policy	Camera, microphone and location off

Logging and alerts

Security log	**Blocks, sign-ins, admin changes**	Retention	**180 days**
Alerts	**Slack and PagerDuty**	Error tracking	**Sentry**

Build and deploy

Every change	**Tests, lint, types, build**	Dependency audit	**High severity fails**
Secret scanning	**Gitleaks on every push**	Deploy	**After checks pass**

Known limits

- Page rate limits run in edge memory per region. Traffic spread across regions counts separately.
- The firewall rules skip multipart uploads.
- Admin IP allow list is set in the Cloudflare dashboard and is not in the repo.